Angry Poutine — Fiche d'exercice

Oct 30, 2026 · François Paquin, CISSP

Mise en situation

Vous êtes analyste au SOC. Une capture réseau a été prise sur le réseau d'un client après une alerte. Votre mandat : déterminer s'il y a eu infection, quel poste est touché, qui l'utilise, ce qui s'est passé et quand.

Vous allez enquêter en trois passes, du plus abstrait au plus détaillé : les **flux** (nfdump), les **paquets bruts** (tcpdump), puis le **décodage complet** (Wireshark). Chaque étape produit des hypothèses que l'étape suivante doit confirmer ou réfuter.

Environnement connu

- Segment LAN : 10.9.10.0/24
- Domaine Active Directory : angrypoutine.com
- Passerelle : 10.9.10.1

Matériel

- Votre VM Kali du cyber range
- Le fichier `angry-poutine.pcap` fourni par l'enseignant
- nfdump (fournit `nfpcapd` et `nfdump`), tcpdump, Wireshark

Consignes de sécurité — à lire avant de commencer

- Ce pcap contient un **vrai maliciel Windows**. Travaillez uniquement dans la VM Kali du cyber range.
- Ne copiez jamais le pcap ni un fichier extrait vers un poste Windows ou personnel.
- Un fichier extrait se manipule par son **hash** seulement : on ne l'ouvre pas, on ne l'exécute pas.
- Les adresses IP et domaines de l'exercice sont réels et malveillants : ne les visitez pas.

Consignes générales

- Toutes les heures sont à donner en **UTC**.
- Pour chaque réponse, notez la commande ou le filtre qui vous l'a donnée. Une réponse sans preuve ne vaut rien en enquête.
- Durée indicative : 45 min (étape 1), 60 min (étape 2), 60 min (étape 3), 15 min (synthèse).

Étape 1 — Les flux (nfpcapd et nfdump)

Objectif : sans voir le contenu d'aucun paquet, repérer le poste suspect, les destinations louches et la chronologie. Vos conclusions sont des **hypothèses**.

Astuce : commencez votre session par `export TZ=UTC`, sinon nfdump affiche l'heure locale.

A. Extraction

1. Convertissez le pcap en flux NetFlow dans un répertoire `./flux`. Combien de fichiers `nfcapd.*` obtenez-vous ? Pourquoi plusieurs fichiers plutôt qu'un seul ?
2. Affichez les statistiques globales des flux. Donnez le nombre de flux, de paquets et d'octets, ainsi que l'heure du premier et du dernier flux (UTC). Quelle est la durée de la capture ?
3. Quelle est la répartition des flux entre TCP, UDP et les autres protocoles ?

B. Qui est qui sur le réseau

4. Quelles adresses IP internes (10.9.10.0/24) apparaissent dans les flux ?
5. L'une d'elles est le contrôleur de domaine. Laquelle ? Justifiez avec au moins trois ports de destination qu'elle reçoit et le service associé à chacun.
6. Quelle adresse génère le plus de trafic (flux et octets) ? Pourquoi est-ce le poste suspect le plus probable ?

C. Les destinations externes

7. Listez les 15 adresses IP qui échangent le plus d'octets. Une grande partie appartient à des fournisseurs connus (Microsoft, Akamai). Pourquoi un poste Windows parle-t-il à autant d'adresses Microsoft ?
8. Affichez tous les flux sur le port 80 (HTTP). Les plus gros transferts (23.1.237.x et 23.3.85.x) appartiennent au réseau de diffusion Akamai. Parmi les autres, une connexion se démarque. Donnez l'IP, l'heure et le volume reçu. Que pourrait-elle représenter ?
9. Quelques secondes après, le poste ouvre une connexion HTTPS vers une autre adresse inconnue avec un volume semblable. Laquelle, à quelle heure, quel volume ?
10. Une adresse externe revient dans plus de 100 flux sur toute la durée de la capture. Laquelle ? Sur quel port ?

D. Le comportement de cette adresse

11. Listez seulement les **débuts** de connexion (paquets SYN) du poste vers cette adresse. Combien de sessions y a-t-il ? Calculez l'intervalle entre les débuts de session successifs. Que remarquez-vous (régularité, regroupement) ?
12. Comparez le total d'octets envoyés et reçus par le poste avec cette adresse. Le volume vous semble-t-il compatible avec une exfiltration massive ?
13. Comment appelle-t-on ce motif de communication ? À quoi sert-il pour un attaquant ?

E. Chronologie et portée

14. Placez dans l'ordre, avec l'heure exacte (UTC) : l'ouverture de session sur le domaine, le téléchargement HTTP suspect, la connexion HTTPS suspecte, le premier contact avec l'adresse récurrente. Combien de secondes séparent le téléchargement du premier contact ?
15. Le poste suspect communique-t-il avec d'autres postes internes que le contrôleur de domaine ? Si oui, est-ce inquiétant ?

F. Bilan de l'étape 1

16. Rédigez en trois à cinq lignes votre hypothèse sur ce qui s'est passé.
17. Nommez au moins quatre informations dont vous auriez besoin pour confirmer votre hypothèse et que les flux **ne peuvent pas** vous donner.

Défi (facultatif) : à 23:17:27.020, une requête DNS de 65 octets part vers le contrôleur de domaine, juste avant le téléchargement. Une requête DNS de type A sans extension fait 44 octets plus la longueur du nom encodé (longueur du nom + 2). Déduisez la longueur du nom demandé, puis vérifiez à l'étape 2. Faites le même calcul pour la requête de 59 octets de 23:17:31.802 : peut-on conclure qu'elle a servi à trouver 167.172.37.9 ?

Étape 2 — Les paquets bruts (tcpdump)

Objectif : confirmer ou réfuter vos hypothèses de l'étape 1 en regardant le contenu des paquets, uniquement en ligne de commande.

Astuces : lisez toujours le fichier avec `-r`, désactivez la résolution de noms avec `-nn`, et filtrez avec une expression BPF entre apostrophes. Vous pouvez enchaîner avec `grep`, `sort`, `uniq -c`.

A. L'identité du poste

1. Affichez le trafic DHCP du début de la capture en mode verbeux. Quel nom d'hôte le poste annonce-t-il ? Dans quelle option DHCP le trouvez-vous ?
2. Quelle est l'adresse MAC du poste suspect ? Quelle option de tcpdump affiche l'en-tête Ethernet ?
3. Dans la réponse du serveur DHCP, quelle adresse IP est attribuée au poste ? Quel serveur DNS et quel nom de domaine lui sont indiqués ?

B. Le DNS

4. Listez toutes les requêtes DNS de type A envoyées par le poste, sans doublons. Combien de noms différents ?
5. Quel nom de domaine a été résolu vers l'adresse du téléchargement HTTP suspect (étape 1, question 8) ? À quelle heure exacte ?
6. Les deux autres adresses suspectes (questions 9 et 10 de l'étape 1) apparaissent-elles dans une réponse DNS ? Qu'est-ce que cela implique sur la façon dont le maliciel les connaît ?

C. Le téléchargement HTTP

7. Affichez en ASCII la requête HTTP vers l'adresse suspecte. Donnez la méthode, le chemin complet de l'URL et l'en-tête `Host`.
8. Quel est le `User-Agent` ? Quelle version de Windows révèle-t-il ?
9. Dans la réponse du serveur, repérez le code de statut, le `Content-Type`, le `Content-Length` et le nom de fichier proposé (`Content-Disposition`). Comparez aussi l'heure de l'en-tête `Date` à l'heure du paquet dans la capture : que remarquez-vous ?
10. Juste après les en-têtes de réponse, quelles chaînes de caractères prouvent que le fichier téléchargé est un exécutable Windows, malgré l'absence d'extension `.exe` ou `.dll` dans l'URL ?

D. Le compte utilisateur

11. Le poste s'authentifie auprès du contrôleur de domaine avec Kerberos (port 88). Affichez ces paquets en ASCII et extrayez les chaînes lisibles. Trouvez-vous un nom de compte utilisateur ? Lequel ? Distinguez-le du compte de l'ordinateur.

E. Le trafic chiffré

12. Pour chaque adresse suspecte en 443, cherchez un nom de serveur (SNI) en clair dans le début de la négociation TLS. Lesquelles en ont un ?
13. Une adresse non identifiée à l'étape 1 a été contactée en 443 vers 23:19 (34.117.59.81). Quel nom DNS a été résolu juste avant ? Ce contact vous semble-t-il lié à l'infection ? Justifiez.

F. La reconnaissance

14. Vers 23:19:22, le poste résout le nom d'un autre poste interne, puis ouvre une session TCP 139 vers lui. Quel est ce nom et quelle est son adresse ? Extrayez les chaînes lisibles de cette session (indice : Windows les encode souvent en UTF-16, voir `strings -e l`). Quel canal nommé est utilisé ?
15. À 23:19:26, le poste ouvre le canal nommé `samr` sur le contrôleur de domaine (port 445). Avec la même technique, trouvez quels groupes du domaine ont été interrogés. Quelles commandes Windows produisent ce trafic ? Pourquoi un attaquant s'y intéresse-t-il ?

G. Bilan de l'étape 2

16. Lesquelles de vos hypothèses de l'étape 1 sont maintenant confirmées ? Lesquelles restent ouvertes ?
17. Qu'avez-vous trouvé difficile ou impossible à faire avec tcpdump seul ? Pensez notamment au fichier téléchargé.

Étape 3 — Le décodage complet (Wireshark)

Objectif : boucler l'enquête, récupérer le fichier malveillant de façon contrôlée et produire des preuves solides.

Avant de commencer : dans Wireshark, réglez l'affichage du temps en UTC (menu View).

A. Vue d'ensemble

1. Ouvrez Statistics > Conversations, onglet IPv4, et triez par octets. Retrouvez-vous le même classement qu'à l'étape 1 ?
2. Ouvrez Statistics > Protocol Hierarchy. Quels protocoles applicatifs sont présents ? Lequel transporte le plus d'octets ?

B. L'identité complète du poste

3. Avec un filtre d'affichage sur le DHCP, confirmez le nom d'hôte et l'adresse MAC.
4. Trouvez le nom du compte utilisateur avec un filtre sur le champ Kerberos `CNameString`. Comment excluez-vous le compte de l'ordinateur ?
5. À quel domaine Kerberos (realm) ce compte appartient-il ?

C. Le téléchargement

6. Affichez seulement les requêtes HTTP. Pour la requête suspecte, donnez l'URL complète telle que Wireshark la reconstruit.

7. Suivez le flux TCP de cette requête (Follow > TCP Stream). Que voyez-vous de plus qu'avec tcpdump ?
8. Ouvrez File > Export Objects > HTTP. Combien d'objets voyez-vous ? Repérez tous les exécutables : sont-ils tous malveillants ? Comment le vérifiez-vous ? Exportez ensuite l'objet suspect **dans la VM seulement** et donnez sa taille.
9. Calculez le SHA256 du fichier et identifiez son type avec la commande `file`. Comparez le hash à celui publié dans les indicateurs de l'exercice (fourni par l'enseignant).

D. Le trafic chiffré

10. Affichez tous les Client Hello TLS et ajoutez une colonne pour le SNI. Quelles connexions suspectes n'ont pas de SNI ? Qu'est-ce que cela indique ?
11. Pour l'adresse récurrente de l'étape 1, examinez le certificat présenté par le serveur. Qui l'a émis ? Est-il signé par une autorité reconnue ? Quand a-t-il été créé ? En quoi est-ce suspect ? Comparez-le ensuite au certificat de 167.172.37.9 : qu'en déduisez-vous ? Enfin, pourquoi seulement une partie des sessions vers le C2 affichent-elles un certificat ?

E. Visualiser le beaconing

12. Ouvrez Statistics > I/O Graphs, intervalle de 10 secondes, avec un graphe filtré sur l'adresse récurrente. Décrivez la forme du graphe. Correspond-elle aux intervalles calculés à l'étape 1 ?

F. La reconnaissance

13. Filtrez sur `lanman`, puis sur `samr`. Quelles requêtes voyez-vous, vers quels postes et à quelle heure ? Associez chacune à une commande Windows.
14. Dans les réponses SAMR, quels comptes l'attaquant a-t-il appris ? Lesquels sont les plus précieux pour lui ? Avec quel compte la session vers DESKTOP-MUYEYV7 a-t-elle été ouverte (regardez le Session Setup) ?

G. Bilan de l'étape 3

15. Nommez le maliciel (famille) avec le hash et une source publique de renseignement, sans téléverser le fichier nulle part.
16. Qu'est-ce que Wireshark vous a apporté que ni nfdump ni tcpdump ne permettaient facilement ?

Synthèse — Rapport d'incident et retour

A. Rapport d'incident (une page maximum)

1. **Résumé exécutif** : trois phrases pour un gestionnaire non technique. Que s'est-il passé, quand, quel est le risque ?
2. **Détails du poste infecté** : adresse IP, adresse MAC, nom d'hôte, compte utilisateur, système d'exploitation.
3. **Chronologie** : les événements clés avec leur heure UTC.
4. **Indicateurs de compromission (IOC)** : domaines, adresses IP et ports, URL, hash SHA256 du fichier.
5. **Recommandations** : trois actions immédiates pour le client.

B. Retour réflexif — complétez le tableau : à quelle étape chaque information est-elle devenue visible pour la première fois ?

Information	Flux (nfdump)	Paquets (tcpdump)	Décodage (Wireshark)
IP du poste infecté			
IP du serveur de téléchargement			
Domaine du téléchargement			
URL complète			
Nature du fichier (exécutable)			
Hash du fichier			
Nom d'hôte			
Compte utilisateur			
IP du C2			
Périodicité du C2			
Certificat du C2			
Reconnaissance (postes et groupes énumérés)			

C. Pour aller plus loin

6. Vous êtes au SOC et vous n'avez que du NetFlow sur ce réseau. Décrivez une règle de détection qui aurait pu lever une alerte sur cette infection, sans connaitre les IOC à l'avance.
7. Selon vous, que s'est-il passé sur le poste **avant** le téléchargement ? Qu'est-ce qui, dans la capture, appuie votre hypothèse ? Qu'est-ce qui n'y est pas ?